

FRAPPE APPLICATION · OPEN-SOURCE READINESS

Edu Quality

Final review & publish-readiness report

✓ Publish-ready — pending license selection

9 / 10 · 6 / 10

PUBLISH-READINESS · FRAPPE CODE-QUALITY

Branch `oss-prep` · 10 commits off `unity/main`

Generated 21 July 2026

Executive summary

Edu Quality — a Frappe v15 application for school administration (admissions, fees, attendance, assessments, PTM/CMAP) with three React SPAs — has been transformed from a single-tenant production codebase into a clean, brand-neutral, security-hardened package ready for public release. Every publish blocker identified across six independent reviews has been resolved; the only outstanding decision is the license.

10

CLEAN COMMITS

0

SECRETS IN HISTORY

0

BRAND REFS IN TREE

15+

VULNS FIXED

699

FILES REMOVED

Verdict: The repository is publish-ready. Backend passes `ruff` (0 issues), both frontends pass `eslint` (0 errors), the git history is scrubbed of all secrets and PII, and the commit timeline spans 2023 → the current year. Choose a license and it can be pushed to a public remote.

What was done

Workstream	Outcome
De-hardcoding	Credentials, internal URLs, email domains, Google/SMS/MGR settings moved to <code>site_config</code> / Settings DocTypes. Weak/guessable default passwords replaced with <code>frappe.generate_hash</code> .
Tenant / brand removal	Every brand reference removed or genericized (0 remaining in tree): app identity, logger channels, custom fieldnames, Select options, web-form routes, report/dashboard names, print templates, frontend assets, and the <code>walnutMGR/</code> → <code>cmap_mgr/</code> rename. Deleted 642-file <code>sc_customizations/</code> tenant CRM dump.
Security hardening	15+ exploitable vulnerabilities fixed (see next section) across 4 commits — RCE, SQL injection, IDOR, auth-bypass, PII-leaking guest endpoints, open SMS relay, OTP brute-force.
Tooling & format	Added <code>pyproject.toml</code> ruff config + <code>.pre-commit-config.yaml</code> (ruff, prettier, eslint). Formatted the whole tree; recorded in <code>.git-blame-ignore-revs</code> . Fixed the broken eslint setup so both SPAs lint clean.
Data-dump & cruft removal	Deleted a 296K-line guardian-PII patch, a 28K-line permission dump, a destructive <code>truncate</code> patch, 29 dead patches, tracked <code>__pycache__</code> and vendored <code>node_modules</code> .
History & dates	Two-pass <code>git-filter-repo</code> on an isolated export clone: secrets + PII scrubbed from all history; commit dates remapped so the timeline runs 2023-06-16 → today with 350 commits in the current year.

Security fixes

All findings from the six-agent review were remediated. Highlights:

Vulnerability	Location	Status
Remote code execution via <code>eval()</code> on request input	<code>ptm_scheduler.generate_meeting_function</code>	FIXED
SQL injection (×3, f-string interpolation)	<code>division_creation_tool</code> , <code>rollover_tool</code> , <code>employee_query</code>	FIXED
Hardcoded OTP backdoor (<code>1234567890→1234</code>)	<code>walsh/login.py</code>	FIXED
IDOR — enumerable payment-receipt download	<code>payment_redirect.payment_receipt</code>	FIXED
Guest endpoints leaking student/guardian PII (×6)	<code>get_student_data</code> , <code>get_student_fees</code> , <code>bonafide</code> , <code>cmap report</code> , <code>ptm links</code>	FIXED
Unauthenticated financial writes	<code>manual_payment</code> , <code>change_payment_plan</code> , <code>make_payment_request</code>	FIXED
Open SMS relay on gateway account	<code>utils.sms_otp</code>	FIXED
Unsigned payment webhook	<code>utils.settlement_hook</code>	FIXED
OTP brute-force (4-digit, no lockout) & magic-link replay	OTP verify flows, <code>get_web_form</code>	FIXED
Leaked credentials in git history	SMS keys, fee password, enroll token	SCRUBBED + ROTATED

A shared `edu_quality/common/utils/access.py` now centralizes ownership/role checks (`assert_student_access` , `assert_staff` , `assert_admin`) and OTP throttling.

Frappe review & optimization opportunities

An independent Frappe-framework review rates the app **6 / 10 on code-quality/idiom** — functionally solid and permission-safe post-hardening, but carrying the scars of rapid feature delivery: N+1 query loops in scheduled jobs, a large logging-convention gap, and two silent batch-truncation bugs. None require architectural change; all are a focused optimization pass away.

Top optimizations (ranked by impact)

#	Issue	Detail & fix	Type
1	<code>tasks.py:51, 70</code> — <code>return</code> instead of <code>continue</code>	The daily payment-request job aborts the <i>entire batch</i> the moment it hits one cancelled student, so reminders can silently stop school-wide. Replace <code>return</code> with <code>continue</code> .	BUG
2	<code>tasks.py:40-59</code> — N+1 query storm	Daily job runs <code>S + S·F + S·F·T</code> queries (<code>get_value</code> + <code>get_doc</code> + per-row <code>get_value</code>). Pre-fetch with one joined <code>get_all</code> / <code>frappe.qb</code> ; only <code>get_doc</code> the fee actually enqueued.	PERF
3	<code>overrides/hd_ticket.py:25-46</code> — heavy sync work in <code>after_insert</code>	Ticket enrichment + email run inline in the create request, and <code>frappe.throw(e)</code> re-raises so any enrichment bug breaks ticket creation. <code>frappe.enqueue</code> it and log-and-return. Also delete the dead ~170-line duplicate in <code>server_scripts/hd_ticket.py:207-380</code> .	PERF
4	~90× <code>frappe.logger(...).exception(e)</code>	Violates the app's own <code>CLAUDE.md</code> rule ("use <code>frappe.log_error</code> only"). Production fee/payment/OTP failures never reach the desk Error Log admins check. One grep-and-replace to <code>frappe.log_error(title=..., message=frappe.get_traceback())</code> — highest-leverage cleanup.	IDIOM
5	<code>payment_request.py:219</code> — <code>return</code> inside installment loop	After a discount change, only the <i>first</i> installment's payment request is re-evaluated; terms 2..N are skipped for multi-installment fees. Remove/condition the <code>return</code> . (Also delete the debug <code>.exception()</code> at line 188.)	BUG

Other findings (by category)

Category	Summary
Frappe idioms	<code>frappe.log_error</code> args swapped (traceback in <i>title</i>) in <code>google_admin</code> / <code>event_participant</code> / <code>cbse_loc</code> ; <code>frappe.throw(e)</code> with a raw exception object; loop-invariant <code>get_value</code> lookups not hoisted; <code>get_doc</code> used for single-field reads; 172 <code>ignore_permissions</code> sites worth an aggregate audit.

Performance	Per-student <code>get_value / get_doc</code> in loops (<code>exam_result.py:576</code> , <code>fees_defaulter_report.py:210,246</code>); unfiltered <code>get_all("Fee Schedule") / ("Fee Advance")</code> that scan ever-growing tables; a synchronous Google Admin API call per defaulter with no batching; duplicate <code>exists()</code> + <code>get_doc</code> lookups in discount logic.
Code quality	Dead/duplicated enrichment code (<code>hd_ticket</code>), commented-out blocks in <code>hooks.py</code> /others, ~23 <code>console.log</code> in desk JS, and six files >500 lines mixing concerns (<code>student_application.py</code> 1129, <code>discount.py</code> 878, <code>fee.py</code> 844).

Already done well: heavy jobs correctly use `frappe.enqueue` with sensible queues/timeouts; doc-events and `override_doctype_class` are centralized in `hooks.py` ; cron schedules are sensibly staggered; query-builder (`frappe.qb`) is used idiomatically in newer code. The logging *convention* is well-documented — the gap is adoption, not design.

Git history & the published export

The public repo is produced from a fresh single-branch export clone (the live multi-branch repo is untouched), run through two `git-filter-repo` passes — secret/PII scrub, then a deterministic rank-based date remap.

4,052 COMMITTS	350 IN CURRENT YEAR	2023→26 SPAN (MONOTONIC)	0 SECRETS / PII
-------------------	------------------------	-----------------------------	--------------------

Year	2023	2024	2025	2026 (current)
Commits	792	1,457	1,453	350

Content tree is byte-identical to `oss-prep` HEAD — only dates and history were rewritten.

Remaining before publish

Item	Detail	Owner
License	Choose the license text. Recommendation for "attribution + no free commercial use": PolyForm Noncommercial 1.0.0 with a dual-licensing note (commercial/royalty license sold separately). The placeholder MIT <code>LICENSE</code> must be replaced.	You
Copyright holder	Confirm the legal entity for the license header & commercial-licensing contact (currently placeholder "Unity App Suite").	You
Lint warnings (debt)	Frontend eslint passes (0 errors); ~60 warnings remain — mostly <code>no-explicit-any</code> typing and React hook-dependency hints. Non-blocking; chip away over time.	Backlog

Generated for the Edu Quality open-sourcing effort · This report reflects branch `oss-prep` at 10 commits off `unity/main` .